



DAS Policy

No:
2100-13

System and Services Acquisition Security Controls

Effective:
April 29, 2025

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

This policy establishes requirements that address system and services acquisition controls for Department of Administrative Services (DAS)-managed information systems, information technology (IT) products, and IT services. This policy outlines the steps that need to be taken at each stage of the **System Development Life Cycle (SDLC)** to protect DAS **IT Resources**.

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards and Technology Special Publication 800-53, "Security and Privacy Controls for Federal Information Systems and Organizations," family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable.

II. Scope

The scope of this policy includes any **DAS-Managed Information Systems and Services** and extends to DAS **External Service Providers**. This policy also applies to DAS business unit managers and system or **Service Owners**.

III. Policy

Each DAS-Managed Information System and Service shall adhere to the following requirements:

- A. **Allocation of Resources (SA-2)**: Prior to any information system acquisition (i.e., buy) and/or development (i.e., build), the requesting DAS business unit shall plan for and allocate adequate resources to:

1. Define and document information security requirements.

2. Determine, document, and allocate the resources required to meet the security requirements.
- B. **SDLC (SA-3):** At a minimum, the following security requirements must be addressed at each stage of the information system or services life cycle:
1. The initiation phase shall at minimum include the following security-related activities:
 - a) **Data** owners shall identify the types of Data to be handled or stored and the corresponding security requirements necessary to ensure **Confidentiality, Integrity** and **Availability**. Data shall be classified in accordance with Ohio Administrative Policy IT- 13, "Data Classification."
 - b) A privacy threshold assessment shall be completed for all information systems and services. For information systems that collect or maintain **Personally Identifiable Information**, business owners shall conduct a privacy impact assessment in accordance with Section 1347.15 of the Ohio Revised Code.
 - c) Determine information security and privacy concepts, standards and processes to be implemented during the information system or service's design and development.
 - (i) Determine security and privacy requirements. As part of this effort, business and system owners shall identify and reference any applicable state or agency policies or standards, as well as any applicable federal, state or local laws.
 - (ii) System and business owners shall conduct a **Preliminary Risk Assessment** that will include a brief description of the basic security needs of the system or service, an overview of the threat environment in which the system or service will operate, and an initial identification of the required security controls in accordance with DAS Policy 2100-08, "Risk Assessment."
 - (iii) For information systems or services where development will be completed in whole or in part by External Service Providers, system, service and business owners shall specify security requirements as required by Section C., Contract Language (SA-4).
 2. During the development phase DAS and/or External Service Provider system developers or Service Owners shall:
 - a) Conduct a risk assessment of the proposed design to determine if security requirements identified during the initiation phase are adequate to mitigate anticipated risks. The risk assessment shall incorporate the risk management processes outlined in DAS Policy 2100-08, "Risk Assessment." Risks identified at this phase shall either be remediated, mitigated by compensating security controls, or formally accepted by the business owner.
 - b) During the initial requirements definition and design phases of information system

development, developers shall identify the functions, ports, protocols, and services intended for system use.

3. During the implementation phase, information systems or services may require various forms of testing as determined by Data classification and risk assessment activities. Vulnerabilities identified by these tests shall be mitigated or accepted and security flaws shall be addressed.
 - a) Conduct security testing in an operational environment to verify functionality, requirements compliance, and sufficiency of the security controls for the intended business environment.
 - b) Conduct security testing as required to verify that the system operates securely and properly when integrated with other IT components such as firewalls and intrusion prevention and detection systems.
 - c) Define conditions when **Independent Validation and Verification** of security controls are required and conduct such Independent Validation and Verification as needed. An example of such a condition may be a system that handles highly **Confidential Data**; and therefore, requires a higher level of assurance.
 - d) System sponsors and stakeholders shall review and analyze information provided at the completion of the implementation phase to determine the system's acceptability.
4. During the operations and maintenance phase information systems or services shall require additional testing, verification and review of security controls.
 - a) System or Service Owners shall conduct appropriate security testing when new industry threats have been identified or when a system is enhanced or changed to ensure that new vulnerabilities are not introduced.
 - b) Verify that the required security controls are functioning as designed and remain effective and sufficient. Verification activities shall include:
 - (i) Security risk assessments.
 - (ii) Antivirus management.
 - (iii) Patch management.
 - (iv) Security testing.
 - (v) Systems audits.
 - (vi) Vulnerability assessments.
 - c) System or service sponsors and stakeholders shall periodically review and analyze current security controls to determine their ongoing appropriateness and effectiveness for current and anticipated risks, and update controls based upon findings.
5. During the disposition phase, the following security controls shall be in place:
 - a) Conduct periodic system or service reviews and plan for termination or transfer.

Develop a plan of action for systems or services selected for termination or transfer.

- b) If appropriate, archive or migrate Data to another system or media to ensure future access, readability and security in accordance with agency record retention schedules.
- c) Sanitize all Data storage media and dispose of state agency IT equipment in accordance with the risk assessment and Ohio Administrative Policy IT-05, "Disposal, Servicing and Transfer of IT Equipment."

C. **Contract Language (SA-4):** All purchase requests or competitive solicitations involving DAS-Managed Information Systems and Services shall be evaluated by OISP to ensure security requirements are addressed prior to execution or release. All acquisition contracts for DAS-Managed Information Systems, information system components, and information system services shall specify, where applicable, the following:

- 1. Security functional requirements, including a description of the functional properties of the security controls to be employed.
- 2. Security strength requirements.
- 3. Security assurance requirements.
- 4. Security-related documentation requirements, including design and implementation information for employed security controls (i.e., security- relevant external system interfaces; high-level and low-level design; network diagrams; and source code or hardware schematics).
- 5. Requirements for protecting security-related documentation.
- 6. Description of the information system development environment and environment in which the system is intended to operate.
- 7. Acceptance criteria.

D. **Information System or Service Documentation (SA-5):** Administrator and user documentation shall be required for all new or upgraded information systems or services. The documentation shall be well-organized and physically secured, preventing unauthorized access. This documentation shall include:

- 1. A system security plan that is based on the template developed by the DAS Office of Information Security and Privacy (OISP).
- 2. A business continuity plan and a disaster recovery plan with specified **Recovery Time Objective (RTO)** and **Recovery Point Objective (RPO)**.
- 3. Documentation that ensures that environmental, management and operational information, useful in follow-on system or service planning and

development, remains available.

4. System or Service Owners shall ensure that security controls and procedures (e.g., access controls and procedures, audit log procedures, security controls document, etc.) are documented for all phases of the SDLC. System or service security documentation shall be:
 - a) Updated to reflect changes in security procedures and controls.
 - b) Maintained as security and infrastructure records as required by Ohio Revised Code (ORC) section 149.433.
 - c) Available for review by authorized personnel only.
 - d) Reviewed as part of system or service security audits.
5. Administrator documentation shall be required for all new information systems. Distribution of administrator documentation shall be limited to technical resources responsible for the administration and security of the information system. Administrator documentation shall contain:
 - a) Details regarding the secure configuration, installation and operation of the information system.
 - b) Effective use and maintenance of security functions/mechanisms.
 - c) Known vulnerabilities regarding configuration and the use of administrative or privileged functions.
6. User documentation shall be required for all new information systems. Distribution of user documentation shall be limited to individuals who use or administer the information system. User documentation shall contain:
 - a) User-accessible security functions/mechanisms and how they are effectively used.
 - b) Methods for interaction with the information system, which enables individuals to use the system in a more secure manner.
 - c) User responsibilities in maintaining the security of the information and information systems and services.

E. **Security Engineering Principles (SA-8):** Information systems and services shall employ security engineering principles as defined by procedures established by OISP to include:

1. Developing layered protections.
2. Establishing sound security policy, architecture, and controls as the foundation for design.
3. Incorporating security requirements into the SDLC.
4. Delineating physical and logical security boundaries.
5. Ensuring that system developers are trained how to build secure software.
6. Tailoring security controls to meet organizational and operational needs.

7. Performing threat modeling to identify use cases, threat agents, attack vectors, and attack patterns as well as compensating controls and design patterns needed to mitigate risk.
 8. Reducing risk to acceptable levels, thus enabling informed risk management decisions.
- F. **External Information System Services (SA-9):** Providers of External Information System Services shall comply with State of Ohio, DAS, and other mandated information security requirements.
1. Oversight and user roles and responsibilities regarding External Information System Services shall be defined and documented. Resources shall be assigned to monitor security control compliance by External Service Providers.
 2. Providers shall identify the functions, ports, protocols and other services required for the use of the contracted service.
 3. Providers shall identify the functions, ports, protocols and other services required by the information system.
 4. Ensure that the following security-related contract termination procedures are completed for all contracted information systems or services:
 - a) Knowledge transfer has occurred between the provider and agency representatives.
 - b) Applications and system components are returned and reincorporated into inventory for appropriate reallocation or disposal.
 - c) State-owned Data is removed from non-agency equipment and returned or destroyed.
 - d) Access and privileges to DAS systems and facilities are removed.
- G. **Configuration Management (SA-10):** Developers, system and Service Owners are responsible for configuration management during design, development, implementation, and operation and ensuring that procedures align with DAS Policy 2100-09, "Configuration Management."
- H. **Developer Security Testing and Evaluation (SA-11):** Developers of information systems shall be required to provide a security assessment plan; perform security testing and validation of the information system; provide evidence of the execution of the assessment plan and the results of the security testing and evaluation; implement a flaw remediation process; and correct flaws identified during security testing and evaluation processes.
1. Test security controls for compliance with security requirements. Testing shall be specific, repeatable and iterative to determine that risk has been mitigated to an acceptable level.

2. Security testing shall include source code reviews as well as application and Database testing for design flaws and common security coding errors, including but not limited to:
 - a) **Buffer Overflows.**
 - b) **Race Conditions.**
 - c) **Command Injection.**
 - d) **Cross-Site Scripting.**
 - e) Poor error handling.
 - f) Exposed application security parameters.
 - g) Insecure temporary files.
 - h) Poor or non-existent session IDs.
3. Security test results shall be evaluated and reviewed with system sponsors and stakeholders to determine if anticipated vulnerabilities have been adequately addressed, if additional vulnerabilities exist, and to what degree they must be remediated to meet acceptable levels.

IV. Definitions

- A. Availability. Ensuring timely and reliable access to and use of information.¹
- B. Buffer Overflow. A condition at an interface under which more input can be placed into a buffer or Data holding area than the capacity allocated, overwriting other information. Attackers exploit such a condition to crash a system or to insert specially crafted code that allows them to gain control of the system.²
- C. Command Injection. Injection flaws occur when an application sends untrusted Data to an interpreter. Injection flaws are very prevalent, particularly in legacy code. They are often found in SQL, LDAP, Xpath, or NoSQL queries; OS commands; XML parsers, SMTP Headers, program arguments, etc. Injection flaws are easy to discover when examining code, but frequently hard to discover via testing.
- D. Confidential Data. This classification includes Data that is required to be protected by law or regulation, is intended for confidential use, and may not be copied or removed from an agency's operational control without authorized permission. This classification includes Data that, if compromised, may result in loss of life, serious injury, or other harm to an individual or group, or disruption to critical agency operations.

¹ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

² "NIST Special Publication 800-28, Guidelines on Active Content and Mobile Code," U.S. Department of Commerce National Institute of Standards and Technology, March, 2008,
<<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-28ver2.pdf>>.

- E. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.³
- F. Cross-Site Scripting. Cross-Site Scripting (XSS) is a type of computer security vulnerability typically found in Web applications. XSS enables attackers to inject client-side script into Web pages viewed by other users.
- G. DAS-managed Information Systems and Services. A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.⁴ This includes internal DAS information systems as well as information systems and infrastructure (services) operated or managed by DAS for customer agencies. For the purposes of this policy, primary responsibility for managing these systems or services may be assigned to DAS OIT personnel or other outside entities.
- H. Data. Coded representation of quantities, objects, and actions. The word, “Data,” is often used interchangeably with the word, “information,” in common usage and in this policy.
- I. External Information System Services. Information systems and services provided by entities outside of State of Ohio government. This includes systems or services contracted by the State of Ohio for use to accomplish state business.
- J. External Service Provider. An entity outside State of Ohio government that provides External Information System Service capabilities to DAS by contract.
- K. Independent Verification & Validation (IV&V). A comprehensive review, analysis, and testing (software and/or hardware) performed by an objective third party to confirm (i.e., verify) that the requirements are correctly defined, and to confirm (i.e., validate) that the system correctly implements the required functionality and security requirements.⁵
- L. Integrity. Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.⁶
- M. IT Resources. Any information technology resource, such as computer hardware and software, IT services, telecommunications equipment and services, digital devices such as digital copiers and facsimile machines, supplies and the Internet, made available to public

³ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁴ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁵ “NIST Special Publication 800-37 Revision 2, Risk Management Framework for Information Systems and Organizations, A System Life Cycle Approach for Security and Privacy,” U.S. Department of Commerce National Institute of Standards and Technology, December 2018 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-37r2.pdf>>.

⁶ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

servants in the course of conducting state government business in support of agency mission and goals.

- N. Personally Identifiable Information. “Personally Identifiable Information” is information that can be used directly or in combination with other information to identify a particular individual. It includes:
 - 1. name, identifying number, symbol, or other identifier assigned to a person,
 - 2. any information that describes anything about a person,
 - 3. any information that indicates actions done by or to a person,
 - 4. any information that indicates that a person possesses certain personal characteristics.⁷
- O. Preliminary Risk Assessment. A Preliminary Risk Assessment defines the threat environment in which the system or application will operate; and establishes an initial description of the basic security needs of the system.
- P. Race Condition. A Race Condition or race hazard is the behavior of an electronic or software system where the output is dependent on the sequence or timing of other uncontrollable events. It becomes a bug when events do not happen in the order the programmer intended.
- Q. Recovery Point Objective (RPO). This describes the latest available point in time from which Data can be restored to be acceptable to the owner(s) of the processes supported by that Data. The Recovery Point Objective is established based on tolerance for loss of Data and helps determine backup frequency requirements.
- R. Recovery Time Objective (RTO). The target time frame for the restoration of a process or service after a disruption has occurred.
- S. Service Owner. A Service Owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT services.
- T. System Development Life Cycle (SDLC). The scope of activities associated with a system, encompassing the system’s initiation, development and acquisition, implementation, operation and maintenance, and ultimately its disposal that instigates another system initiation.⁸

V. Authority

ORC 125.18

⁷ Based on Ohio Revised Code Section 1347.01 (E).

⁸ Swanson, Marianne, Pauline Bowen, Amy Wohl Phillips, Dean Gallup, David Lynes. “NIST Special Publication 800-34 Revision 1, Contingency Planning Guide for Federal Information Systems,” U.S. Department of Commerce National Institute of Standards and Technology, May 2010, <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-34r1.pdf>>.

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio Administrative Policy IT-05 Disposal, Servicing and Transfer of IT Equipment	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-08 Risk Assessment	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-09 Configuration Management	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
12/22/2017	Original Policy

Date	Description of Change
12/04/2018	Conducted scheduled maintenance review, no changes were made to the policy as a result.
06/10/2020	Updated the policy template to align with the current format.
09/30/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.
04/29/2025	Replaced the term sensitive data, or sensitive information, with confidential data.